



Моделирование угроз

Как систематически найти угрозы, которые мы могли не заметить при формулировании требований?

Факультет компьютерных наук

Бакалаврская образовательная программа 09.03.04 «Программная инженерия» · 3 курс

Дисциплина «Разработка безопасного программного обеспечения» · 2026/2027 учебный год



Секция 1

Зачем нужна модель

От списка догадок — к воспроизводимому обходу продукта



Исходная точка: сервис гостевых пропусков

3 / 48

Продукт

сотрудник создаёт заявку на визит и указывает имя и email гостя

сервис сохраняет заявку и отправляет гостю персональную ссылку

оператор исправляет заявки

администратор управляет ролями

Рабочие требования

SR-01

сотрудник может просматривать и изменять только созданные им заявки на визит

SR-02

назначать и изменять роли может только администратор

Учебный пример лекции



Требования уже есть. Но что мы могли пропустить?

4 / 48

SR-01

сотрудник может просматривать и изменять только созданные им заявки на визит

SR-02

назначать и изменять роли может только администратор

Сценарии, которых в требованиях пока нет

персональная ссылка гостя

внешняя почтовая служба

список для охраны

журнал действий

Новый путь нарушения уже существующего требования

прямой вызов административного действия → против SR-02

**Модель помогает и находить новые требования,
и видеть новые пути нарушения уже известных свойств**



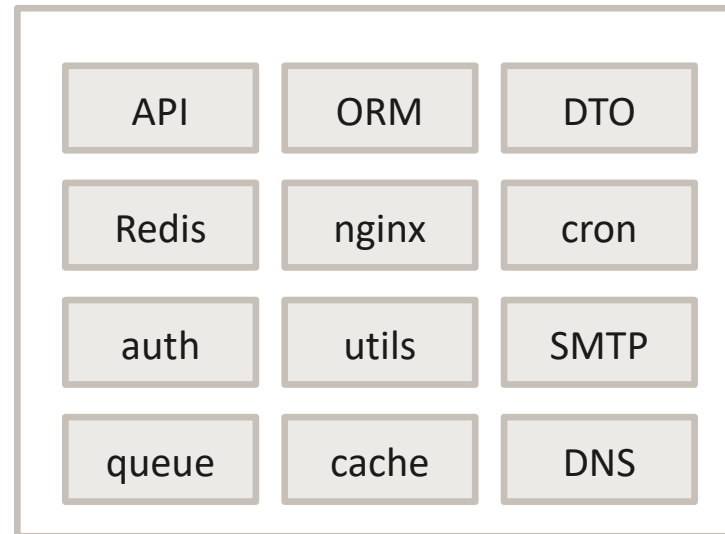
Какая модель действительно достаточна?

5 / 48

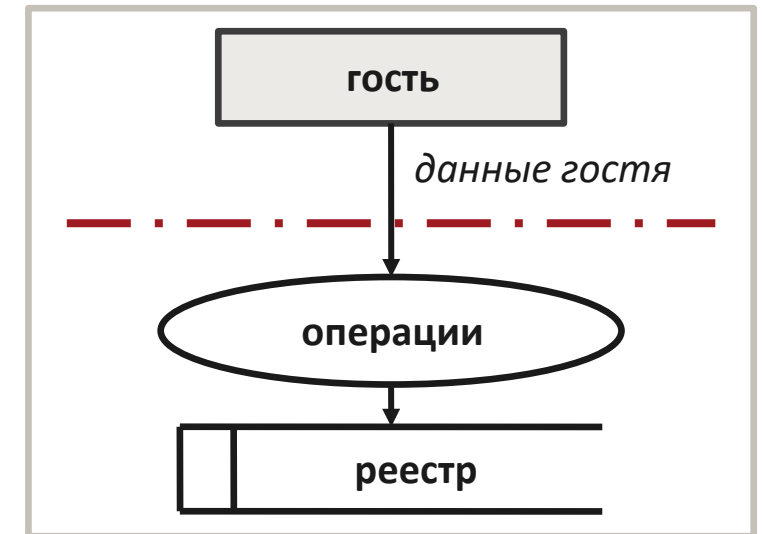
Слишком грубо



Слишком подробно



Достаточно для анализа



Какая модель полезна для поиска угроз — и по какому признаку?

Можно проследить путь значимого актива и увидеть места, где меняются основания доверять данным или полномочиям



Модель системы задаёт воспроизводимый маршрут анализа

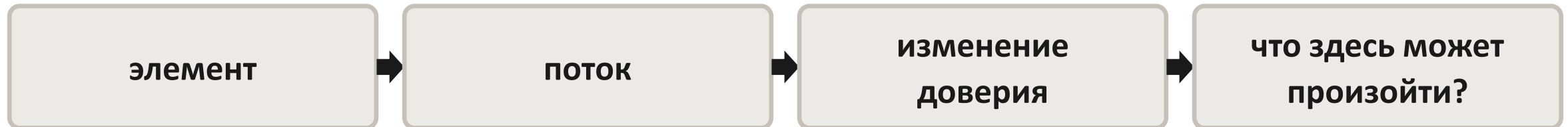
6 / 48

Модель системы

— упрощённое представление продукта, достаточное для рассуждения о его элементах, данных, взаимодействиях и границах доверия.

модель для анализа $\neq$ полная архитектурная документация

Маршрут анализа по модели



Модель не гарантирует абсолютной полноты, но делает поиск систематическим и воспроизводимым другим участником

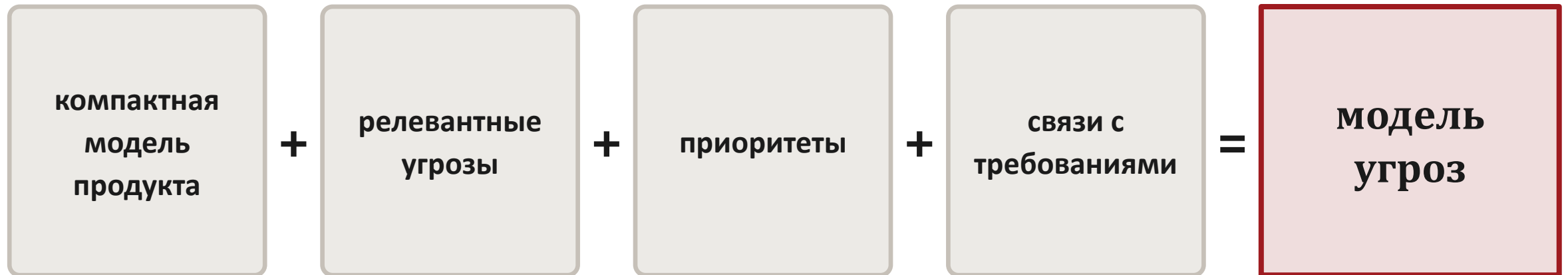


Что мы называем моделью угроз

7 / 48

Модель угроз

— компактное представление продукта (значимых элементов, потоков данных, границ доверия и активов) вместе с набором релевантных угроз, их приоритетом и связями с требованиями безопасности.





Секция 2

Минимальная модель: DFD

Для анализа достаточно нескольких типов элементов и осмысленных потоков



DFD — схема движения данных

9 / 48

DFD (диаграмма потоков данных)

— схема, показывающая, как данные перемещаются между внешними субъектами, процессами и хранилищами. В курсе применяется минимальная нотация, достаточная для отображения значимых потоков и границ доверия.

**Нас интересует движение значимых данных,
а не точная схема физической сети**





Четыре элемента достаточны для начала

10 / 48

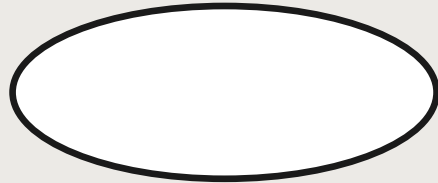


Внешний субъект

кто взаимодействует
с продуктом извне

ПРИМЕР

гость



Процесс

что принимает,
преобразует или
передаёт данные

ПРИМЕР

операции с заявками

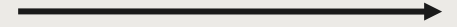


Хранилище

где данные значимо
сохраняются

ПРИМЕР

реестр заявок



Поток данных

какие данные и в
каком направлении
передаются

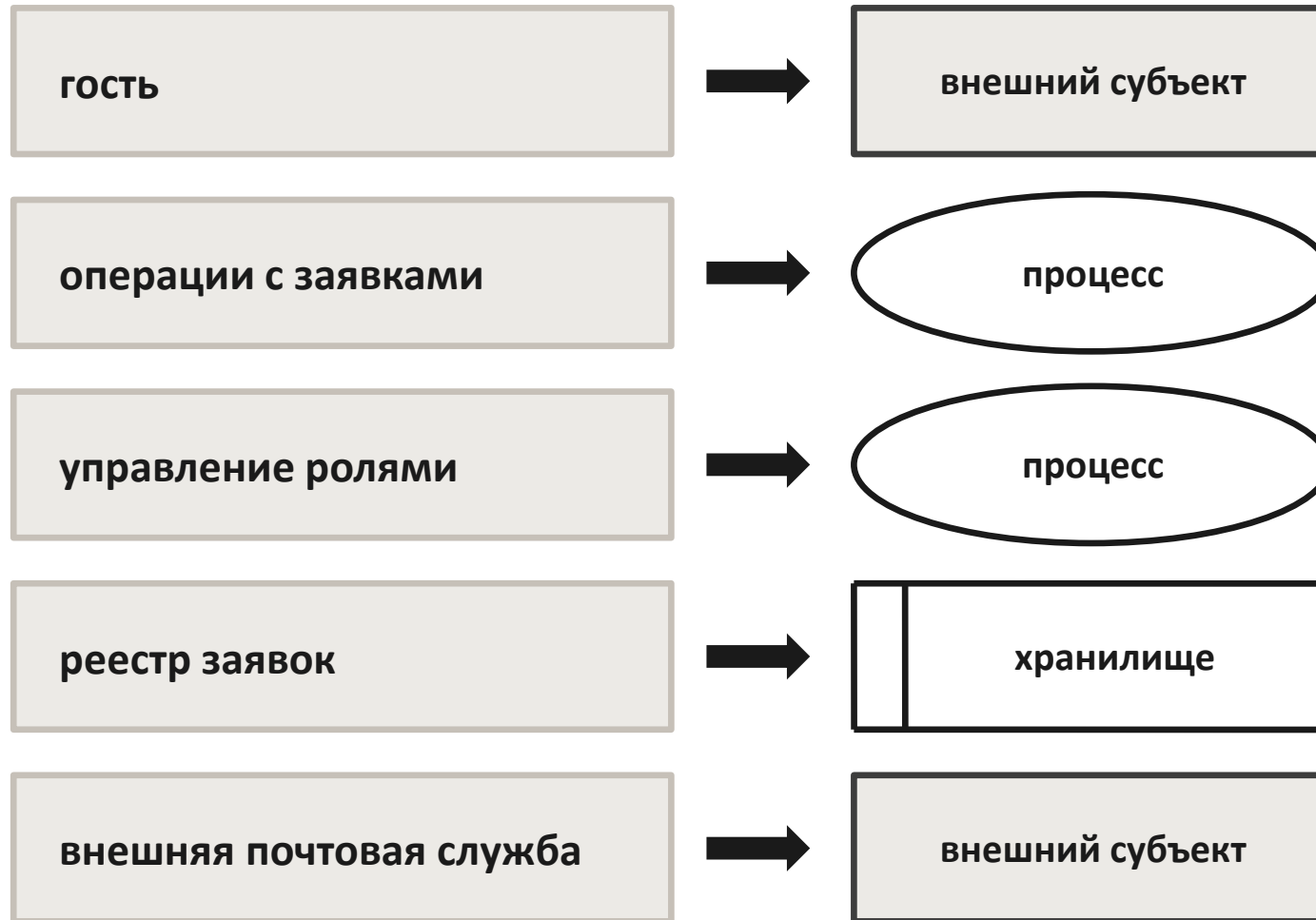
ПРИМЕР

персональная ссылка



Субъект, процесс или хранилище?

11 / 48



Субъект — по роли

сотрудник, оператор,
администратор, а не общее
«пользователь»

Разделять по смыслу

если различаются полномочия,
данные или последствия нарушения
— даже в одном приложении или
одной БД



Поток подписывается данными, а не транспортом

12 / 48

Поток данных

— перемещение данных между внешними субъектами, процессами и хранилищами в модели системы.

СЛАБО

HTTPS · REST · SMTP

ПОЛЕЗНО

*данные заявки · персональная ссылка ·
данные гостя · список посетителей*

Запрос и ответ — два потока, если они переносят разные данные: у них могут быть разные угрозы

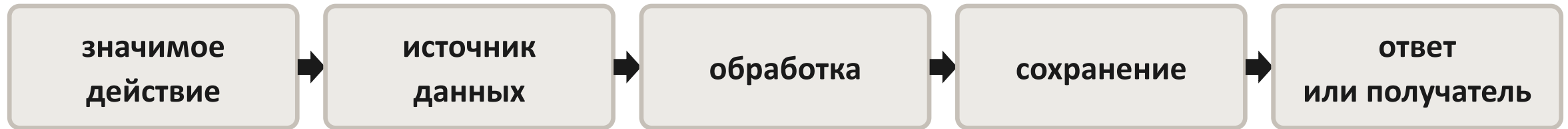
**Название транспорта не объясняет, что именно
можно раскрыть, изменить или подменить**



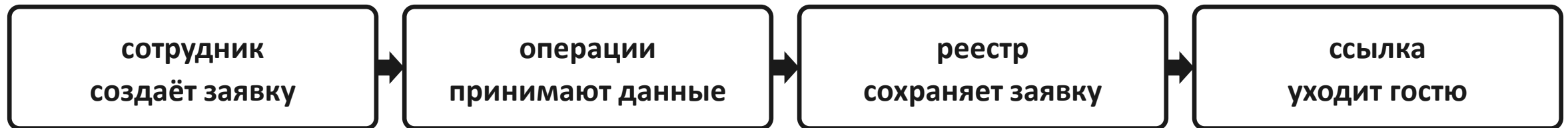
Модель строится от сценария

13 / 48

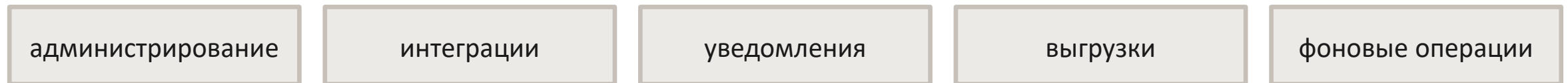
Порядок построения



Для сервиса пропусков



Затем добавляются



DFD — учебная нотация, а не обязательный формат документа



Секция 3

Потоки и границы доверия

Граница появляется там, где меняется основание доверять данным или полномочиям



Сквозной пример: сценарий и активы

15 / 48

Сценарий

сотрудник создаёт заявку, указывает имя и email гостя

сервис сохраняет заявку и отправляет персональную ссылку

гость уточняет сведения по ссылке

оператор исправляет заявки и запускает список

администратор управляет ролями

список посетителей передаётся охране

Напоминание

Актив

— данные, функция, ресурс или состояние продукта, нарушение значимого свойства которых способно причинить ущерб.

Активы примера

персональные данные гостя и заявка

корректность ролей и полномочий

персональные данные и достоверность списка

журнал действий как источник подотчётности

Рабочее определение курса



Шаг 1. Кто взаимодействует и какие процессы различаем?

16 / 48





Шаг 2. Где хранятся данные и какие службы участвуют?

17 / 48





Шаг 3. Теперь показываем данные

18 / 48





Граница доверия — изменение оснований доверять

19 / 48

Граница доверия

— линия в модели системы, при пересечении которой меняются основания доверять данным, субъекту или его полномочиям. Такие пересечения являются приоритетными точками анализа угроз.

**Что изменилось, из-за чего эти данные или полномочия
теперь нужно оценивать иначе?**

ГРАНИЦА ПО ПРИВЫЧКЕ

пунктир «внутренняя сеть» без объяснения,
какое доверие меняется

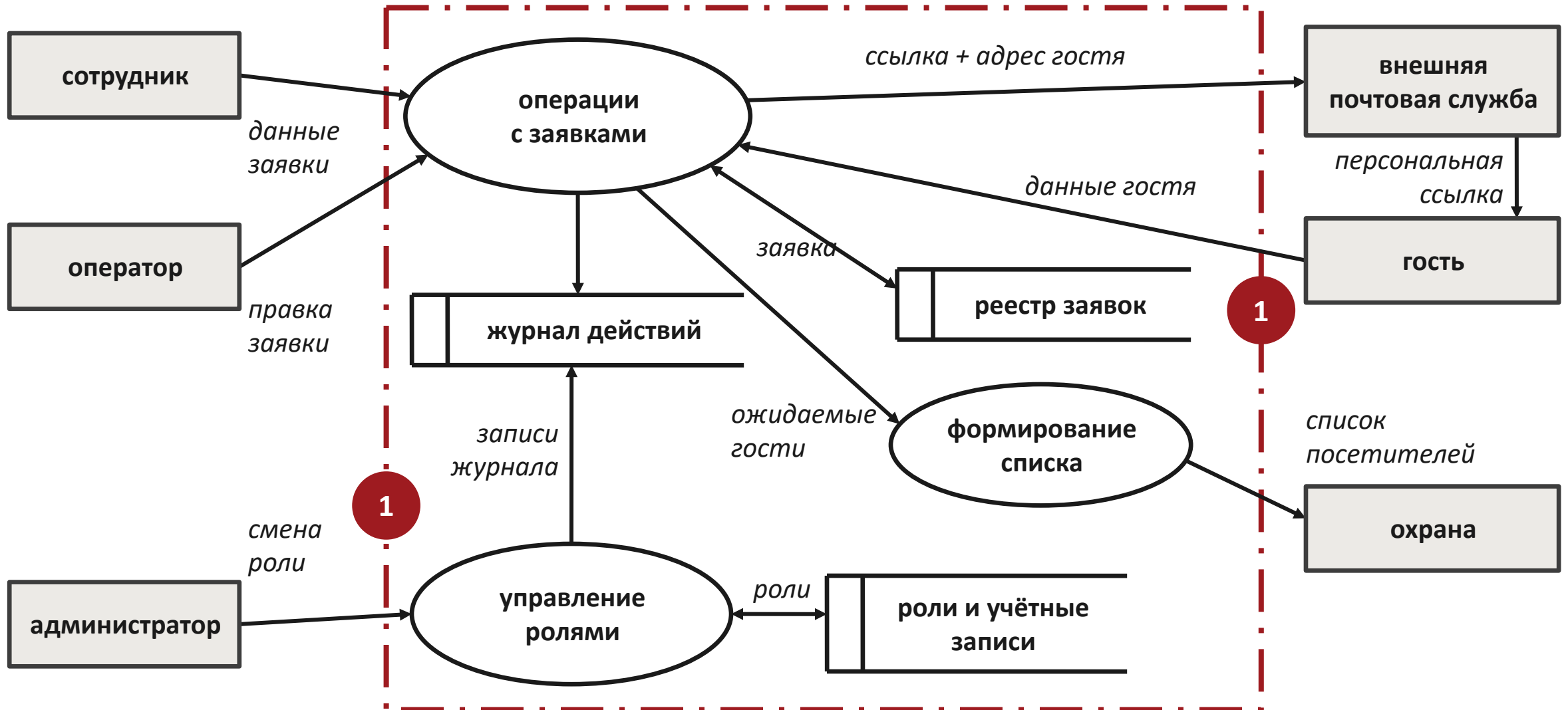
СОДЕРЖАТЕЛЬНАЯ ГРАНИЦА

названо, что меняется: кто формирует данные и
какие полномочия у субъекта



Где здесь действительно меняются основания доверия?

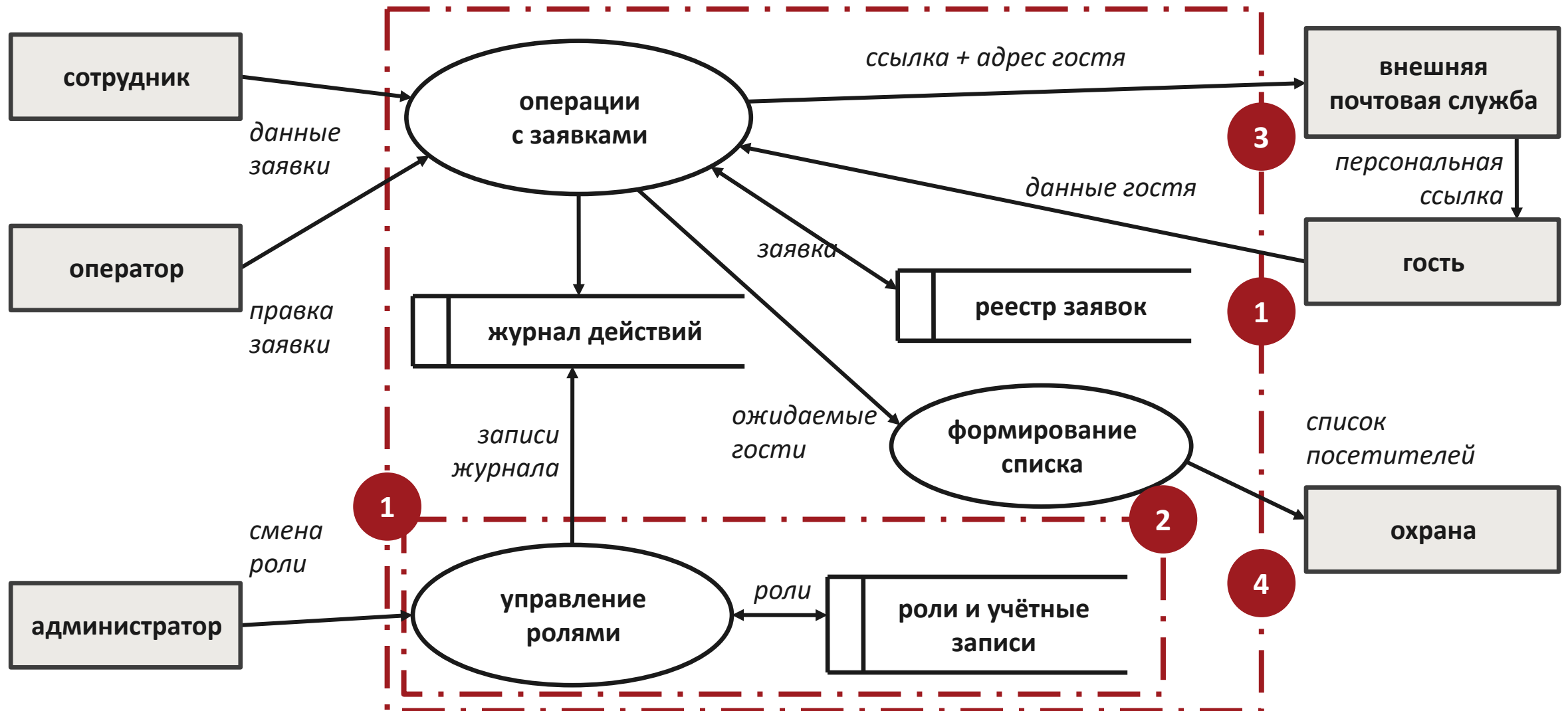
20 / 48





У одной модели — разные основания доверия

21 / 48





Четыре границы — четыре разные причины

22 / 48

1 Клиенты ↔ серверные процессы

Запрос из браузера любой роли проверяет сервер; у гостя подлинность вообще не установлена

2 Обычные роли ↔ управление ролями

Меняется допустимый набор действий, хотя всё работает в одном приложении

3 Продукт ↔ внешняя почтовая служба

Ссылка и адрес гостя уходят в систему с другим контролем и сроком хранения

4 Продукт ↔ охрана

Список с персональными данными попадает во внешний контур со своими правилами

**Граница описывает причину пересмотра доверия,
а не географию схемы**



Аутентифицированный запрос всё равно может быть недоверенным вводом

23 / 48

Недоверенный ввод

— данные, поступающие из-за границы доверия. Они не считаются корректными или допустимыми автоматически.

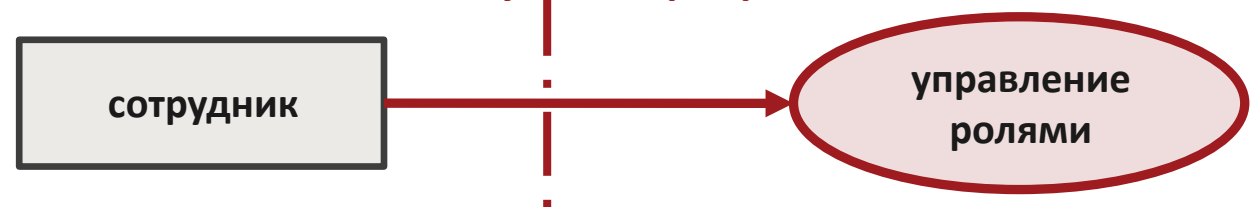
Ложные гарантии

административная кнопка скрыта

значение роли лежит в hidden-поле

JavaScript проверил допустимость

Что на самом деле получает сервер



технически достижимо, не штатный поток

**Аутентификация отвечает на вопрос «кто?»,
но не делает каждую присланную операцию допустимой**



Секция 4

От модели к конкретной угрозе

Угроза — событие против значимого свойства, а не название категории или дефекта



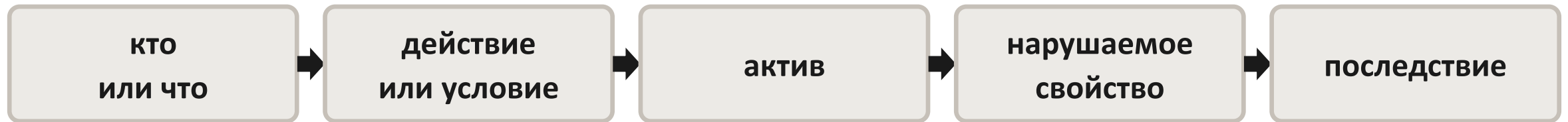
Что такое угроза

25 / 48

Угроза

— конкретный потенциальный сценарий события или действия, способного нарушить значимое свойство продукта.

Рабочая форма



Какими словами называть нарушаемое свойство

конфиденциальность	целостность	доступность
подлинность субъекта	подотчётность действия	авторизация (соблюдение полномочий)

Это диагностический словарь, а не жёсткое соответствие «буква STRIDE — одно свойство»

Рабочее определение курса



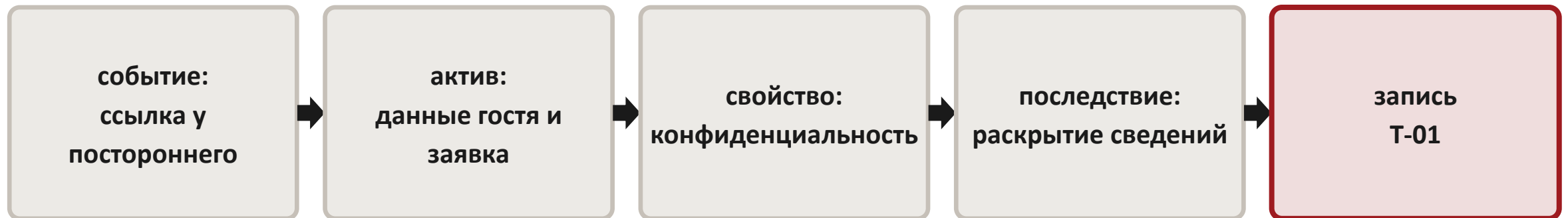
Как получить угрозу из элемента модели

26 / 48



Что произойдёт, если ссылка окажется у другого человека?

Цепочка от элемента модели





Угроза ≠ уязвимость

27 / 48

Уязвимость

— слабость системы, которую можно использовать для нарушения безопасности при определённых условиях.

Угроза — что может произойти

**посторонний получает
действительную персональную ссылку
гостя и читает данные заявки этого
гостя**

Возможные уязвимости — что облегчит сценарий

ссылка предсказуема

ссылка бессрочна или многократно

ссылка даёт право изменения без подтверждения

отзыв ссылки не предусмотрен или не работает

**На этапе модели угроз конкретная уязвимость
может быть ещё неизвестна**



T-01. Персональная ссылка попадает постороннему

28 / 48



T-01 — посторонний получает действительную персональную ссылку гостя и читает или изменяет данные заявки этого гостя

КТО ИЛИ ЧТО

посторонний получатель ссылки

ДЕЙСТВИЕ

использует действительную ссылку гостя

АКТИВ

данные гостя и заявка

НАРУШАЕМОЕ СВОЙСТВО

конфиденциальность; при изменении — целостность

ПОСЛЕДСТВИЕ

раскрытие и искажение персональных сведений

ЭЛЕМЕНТ МОДЕЛИ

поток через внешнюю почтовую службу



Т-02. Обычный сотрудник выполняет административное действие



Т-02 — обычный сотрудник напрямую обращается к процессу управления ролями и назначает себе роль оператора

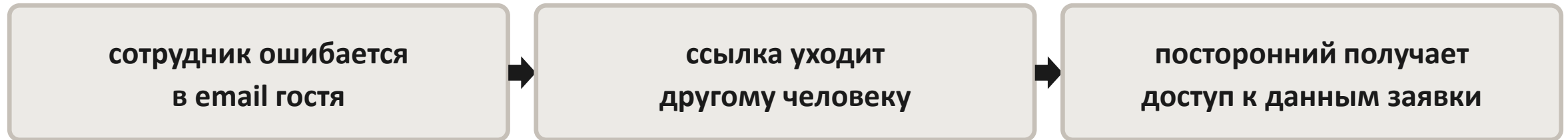
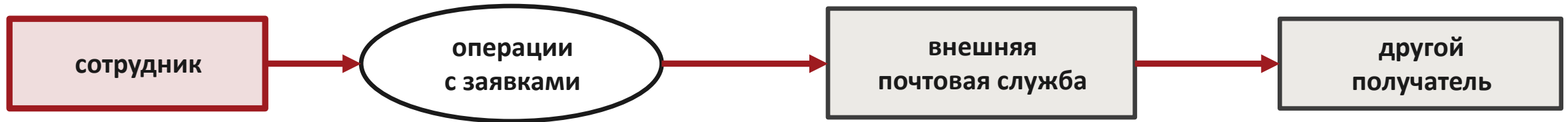
КТО ИЛИ ЧТО аутентифицированный сотрудник	ДЕЙСТВИЕ напрямую вызывает административное действие
АКТИВ корректность ролей и полномочий	НАРУШАЕМОЕ СВОЙСТВО авторизация; целостность состояния ролей
ПОСЛЕДСТВИЕ функции оператора и чужие заявки	ЭЛЕМЕНТ МОДЕЛИ управление ролями, хранилище ролей, граница 2

Скрытая административная кнопка не исключает угрозу



У угрозы не обязательно есть злоумышленник

30 / 48



Тоже события без злого умысла



**Важны нежелательное событие и его последствия,
а не обязательное наличие злого человека**



Категория, дефект, слабость или угроза?

31 / 48

1

Раскрытие информации (Information Disclosure)

КАТЕГОРИЯ STRIDE

2

SQL-инъекция (SQL injection)

КЛАСС ДЕФЕКТОВ

3

Сервер не проверяет, что сотрудник обращается к собственной заявке

ВОЗМОЖНАЯ УЯЗВИМОСТЬ

4

Посторонний получает персональную ссылку гостя и читает данные его заявки

КОНКРЕТНАЯ УГРОЗА

Где категория, класс дефектов, уязвимость и угроза?

Угроза — нежелательное событие в контексте продукта



Секция 5

STRIDE как вопросник

Шесть направлений поиска — не шесть обязательных строк реестра



Что такое STRIDE

33 / 48

STRIDE

— эвристика поиска угроз по шести классам: подмена идентичности, несанкционированное изменение, отрицание совершённых действий, раскрытие информации, отказ в обслуживании и повышение привилегий.

S

подмена

T

изменение

R

отрицание

I

раскрытие

D

отказ

E

повышение

категория

вопрос к элементу
модели

предметный
сценарий-кандидат

**STRIDE помогает задавать вопросы;
буква не является готовой угрозой**



Первые три вопроса STRIDE

34 / 48

S *Spoofing*

Подмена идентичности

**Может ли кто-то
действовать от имени
другого субъекта?**

ТИПИЧНО ЗАТРАГИВАЕТСЯ
подлинность субъекта

T *Tampering*

**Несанкционированное
изменение**

**Можно ли изменить
данные или состояние без
нужного права?**

ТИПИЧНО ЗАТРАГИВАЕТСЯ
целостность

R *Repudiation*

**Отрицание совершённых
действий**

**Можно ли совершить
значимое действие так,
что потом нельзя
установить его автора?**

ТИПИЧНО ЗАТРАГИВАЕТСЯ
подотчётность действия

Связь буквы со свойством типичная, а не формальная один-к-одному



Ещё три вопроса STRIDE

35 / 48

I *Information Disclosure*

Раскрытие информации

Можно ли получить
данные без нужного
права?

ТИПИЧНО ЗАТРАГИВАЕТСЯ
конфиденциальность

D *Denial of Service*

Отказ в обслуживании

Можно ли сделать
значимую функцию или
ресурс недоступными?

ТИПИЧНО ЗАТРАГИВАЕТСЯ
доступность

E *Elevation of Privilege*

Повышение привилегий

Можно ли выполнить
действие более
привилегированной
роли?

ТИПИЧНО ЗАТРАГИВАЕТСЯ
авторизация (соблюдение
полномочий)

Связь буквы со свойством типичная, а не формальная один-к-одному



Пройдём STRIDE по потоку «персональная ссылка»

36 / 48



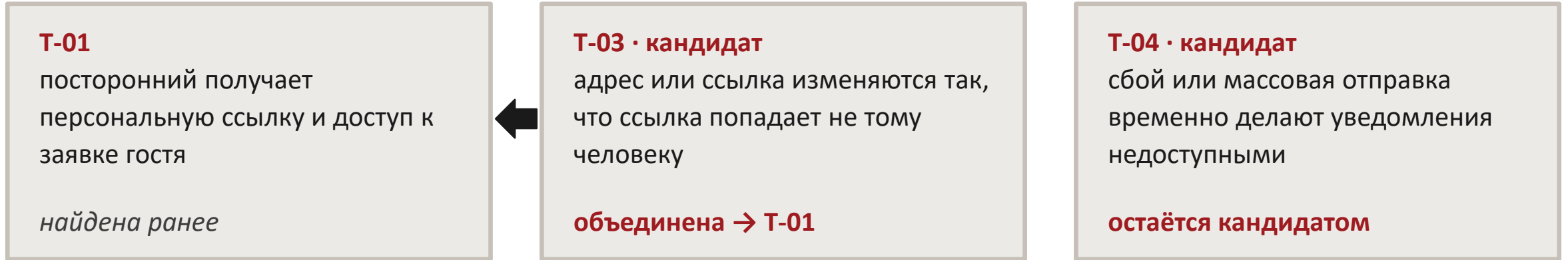
S	посторонний использует чужую ссылку как приглашённый гость	→ T-01
T	адрес получателя или ссылка изменяются при передаче	→ T-03, кандидат
R	для этого потока содержательного кандидата нет	нет кандидата
I	ссылка раскрывается постороннему	→ T-01
D	массовая отправка или сбой почты делают уведомления недоступными	→ T-04, кандидат
E	повышение привилегий к этому потоку не относится	нет кандидата

Шесть вопросов дали не шесть угроз



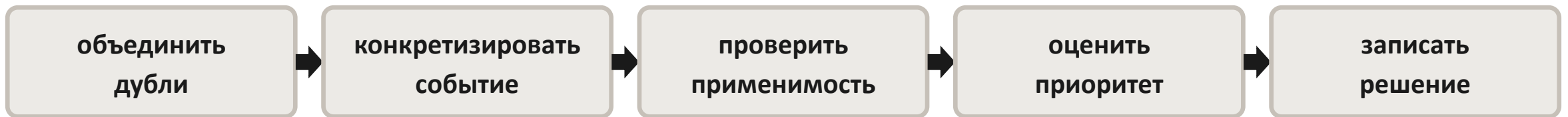
STRIDE производит кандидатов, а не готовый реестр

37 / 48



T-03 после конкретизации: ссылка попадает постороннему — это тот же предметный сценарий, что и T-01

Порядок обработки кандидатов



Каждый кандидат получает явную судьбу



Секция 6

Применимость, приоритет и живой реестр

Найти кандидата недостаточно: нужно объяснить, насколько он важен и с чем связан



Сначала: применим ли кандидат к продукту?

39 / 48

- 1 Соответствие продукту** — есть ли в продукте такой актив, функция, субъект или поток?
- 2 Возможность сценария** — допускают ли функции и подтверждённые предпосылки это событие?
- 3 Значимое последствие** — затронут ли актив или заинтересованная сторона?
- 4 Подтверждённые гарантии** — есть ли установленное свойство, исключаящее сценарий?

«Внутри сети» и «кнопка скрыта» — не подтверждённые гарантии

Пример отбрасывания

T-05 · КАНДИДАТ

посторонний получает платёжные данные гостя

РЕШЕНИЕ: ОТБРОШЕНА

сервис не принимает и не хранит платёжные данные: такого актива нет

УСЛОВИЕ ПЕРЕСМОТРА

появится оплата пропуска, парковки или иная обработка платежей

Применимость — возможен ли сценарий вообще.

Приоритет — другой вопрос



Затем: какой относительный приоритет?

40 / 48

Условия реализации

какие предпосылки нужны и насколько легко или часто сценарий может возникнуть сейчас

Тяжесть последствий

что происходит с активом, основным сценарием и заинтересованными сторонами

Шкала учебного проекта

высокий

средний

низкий

редкое событие $\neq$ автоматически низкий

простое событие $\neq$ автоматически высокий

**Числовой расчёт риска не требуется: приоритет —
относительное инженерное решение с объяснением**



Какой сценарий требует внимания в последнюю очередь?

41 / 48

T-01

ВЫСОКИЙ

посторонний получает
персональную ссылку и читает или
изменяет заявку гостя

T-02

ВЫСОКИЙ

сотрудник назначает себе роль
оператора через
административный процесс

T-04 · кандидат

НИЗКИЙ

сбой или массовая отправка
временно делают уведомления
недоступными

Что требует внимания в последнюю очередь — и почему?

УСЛОВИЯ

достаточно ошибки в адресе или
пересылки; злой умысел не нужен

УСЛОВИЯ

нужен сотрудник и технически
достижимое обращение

УСЛОВИЯ

нужен сбой внешней почты или
пиковая отправка

ПОСЛЕДСТВИЯ

раскрытие или изменение
персональных данных

ПОСЛЕДСТВИЯ

изменение полномочий открывает
действия вне роли

ПОСЛЕДСТВИЯ

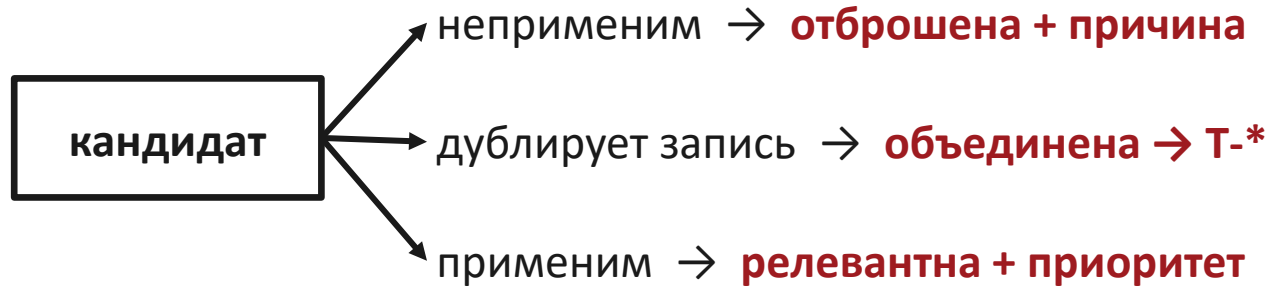
уведомления временно недоступны,
но ручной путь сохраняет визит

Это не универсальные оценки и не расчёт риска: при изменении контекста приоритет пересматривается



Статус, приоритет и условие пересмотра — разные поля

42 / 48



На нашем примере

T-05 → отброшена: платёжного актива нет

T-03 → объединена → T-01

T-04 → релевантна, низкий, с условием пересмотра

T-01, T-02 → релевантны, высокий

Карточка T-*

T-ID и краткое имя	статус
полная формулировка	приоритет (для
элемент модели	релевантной)
актив	связанные SR-*
нарушаемое свойство	причина решения
последствие	условие пересмотра

Условие пересмотра — отдельное поле для решения, зависящего от изменяемого предположения



Угроза связывается с требованием через свойство

43 / 48



SR-03 · ЧЕРНОВИК

доступ по персональной ссылке — только в период актуальности заявки и к минимально необходимым
данным; одна ссылка не позволяет изменять данные гостя

позже

**Нет подходящего SR — дополняем требования,
а не отбрасываем угрозу**



Модель угроз — живой инженерный артефакт

44 / 48

Модель строят до выбора защитных решений и пересматривают после существенных изменений

Когда пересматривать

новый внешний интерфейс

новая роль или полномочия

новое хранилище

новая внешняя служба

изменение потока

изменение предположения

На нашем примере

ручное оформление визита отменили

предположение для T-04 исчезло

пересмотреть приоритет T-04

Маршрут пересмотра

изменение

затронутые
элементы и потоки

границы
доверия

T-* и статусы

связи с SR-*
и приоритеты

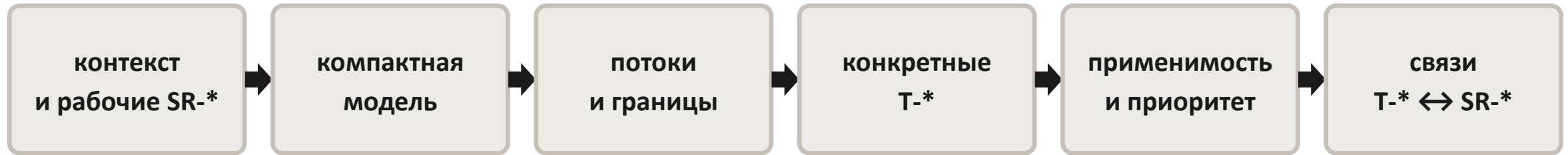
Старую запись не стирают: статус и условие пересмотра сохраняют историю инженерного решения



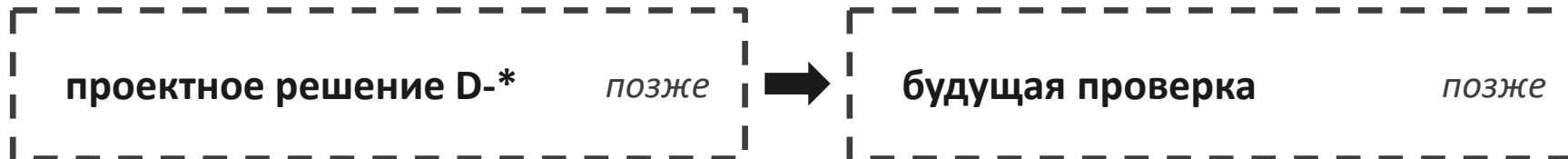
Граница сегодняшнего результата

45 / 48

Сегодня



Следующий инженерный шаг



Сегодня: что может нарушить требуемое свойство.
Как его обеспечивать — следующий инженерный шаг



Проверка переноса и пять выводов

46 / 48

1

Модель делает поиск воспроизводимым, но не гарантирует абсолютной полноты

2

Граница — изменение оснований доверять, а не обязательно сетевой периметр

3

Угроза — конкретный сценарий против значимого свойства;
уязвимость — слабость

4

STRIDE — вопросник: несколько классов могут дать одну угрозу,
часть — ни одной

5

Релевантная угроза получает статус, приоритет и связь с SR-*;
модель живёт вместе с продуктом



Следующий шаг — семинар 03

47 / 48

**На семинаре: построить компактный архитектурный вид
собственного продукта и получить из него конкретные угрозы**

К концу занятия

архитектурный вид с потоками и точками входа

хотя бы одна содержательная граница доверия

несколько конкретных T-*

связи T-* ↔ SR-*

предварительные относительные приоритеты

Пока не требуется

DFD как обязательный формат

фиксированное число границ

все шесть категорий STRIDE

отдельная матрица трассировки

числовой расчёт риска

готовые проектные решения D-*

защитные механизмы и будущие проверки

2–3 угрозы — ориентир по времени

